When the Alarm Sounds

Guia de estudo — Resposta a Incidentes (IR) · Projeto DLH · MedDefense Health Systems

Este guia explica **o que você precisa entender** para fazer as 7 tarefas (0 a 6). Para cada uma: objetivo, conceitos, como pensar, armadilhas e um resumo do que aprender.

Visão geral do projeto

Cenário: a MedDefense tem 3 hospitais, 2.000 funcionários e prontuários de pacientes. Ela *detecta* bem, mas *responde* mal: "pessoas ligam para pessoas", decisões no corredor, nada escrito. Você vai construir a capacidade formal de resposta a incidentes.

O pedido do chefe (James Chen): nada de "papel teórico". Ele quer documentos que um analista de plantão abra às 2h da manhã e siga **sem precisar ligar para ninguém**.

Pessoa	Cargo	Papel provável no IR
Dr. Patricia Morales	CISO	Executive Sponsor / autoridade SEV1
James Chen	SOC Lead	IR Commander
Sarah Park	IT Director	Backup executivo / recursos de TI
Robert Kim	Infrastructure Lead	Technical Lead ou backup do IR Commander
Mike Torres	Network Engineer	Backup técnico (isolamento de rede, segmentação)
Helena Reyes	General Counsel	Legal Liaison (HIPAA, notificações)
Marcus Webb	Communications Director	Communications Lead

As entregas formam um sistema

1. `severity_matrix.md` → define **quão grave** é.
2. `ir_team_structure.yaml` → define **quem decide e quem é chamado**.
3. `playbook_template.yaml` → define **o formato padrão** dos procedimentos.
4. `playbook_credential_exposure.yaml` e `playbook_clinical_degradation.yaml` → procedimentos **concretos**.
5. Tarefa 6 → você **testa** tudo contra um alerta real.

Ponto crítico: os arquivos precisam ser **coerentes entre si**. Se a matriz diz que SEV1 é decidido pelo "CISO", a estrutura de time deve ter um papel (ex.: Executive_Sponsor) com `authority_ceiling: SEV1`. Se o playbook diz "owner: IR_Commander", esse papel tem que existir no YAML do time. Use sempre os **mesmos nomes**.

Analogia: pense no pronto-socorro. A **triagem** (cores vermelho/amarelo/verde) é a matriz de severidade. A **escala de plantão** é a estrutura do time. Os **protocolos clínicos** (ex.: protocolo de AVC) são os playbooks. O **formulário padrão de protocolo** é o template. E o **simulado** é a tarefa 6.

Vocabulário essencial

Termo	Significado
Evento vs. Incidente	Evento = qualquer ocorrência observável (um login). Incidente = evento que viola ou ameaça violar políticas de segurança (login de atacante).
IR (Incident Response)	Processo organizado de lidar com incidentes: preparar, detectar, conter, erradicar, recuperar, aprender.
Playbook	Roteiro passo a passo para um tipo específico de incidente.
IOC	Indicator of Compromise: IP, hash, domínio, padrão de log que indica ataque.
TTP	Tactics, Techniques and Procedures — o "modo de operar" do atacante (MITRE ATT&CK).
PHI / ePHI	Protected Health Information (eletrônica): dados de saúde identificáveis. Protegidos pela HIPAA.
HIPAA Breach Notification Rule	Regra (45 CFR 164.400–414) que obriga notificar pacientes/HHS em caso de violação de PHI.
Epic / EHR	Epic é o software de prontuário eletrônico (Electronic Health Record) mais usado nos EUA.
Downtime procedures	Procedimentos de contingência do hospital quando o sistema cai (papel, formulários manuais).
Chain of custody	Registro de quem coletou/manipulou cada evidência, para ela ter valor legal.

Tarefa 0 — Mapear o ciclo de vida num incidente real

Tipo: quiz (múltipla escolha). **Objetivo:** reconhecer cada fase do ciclo NIST dentro de uma linha do tempo real.

O ciclo de vida NIST SP 800-61r2 (4 fases)

Fase	O que acontece
1. Preparation	Tudo que existe *antes* do incidente: plano de IR, time, playbooks, ferramentas, backups, treinamento. **(É o que você constrói neste projeto.)**
2. Detection & Analysis	Perceber sinais (alertas, tickets), validar se é incidente, avaliar escopo e severidade, documentar, notificar.
3. Containment, Eradication & Recovery	Conter (parar a propagação), coletar evidências, erradicar (remover o atacante/malware, contas comprometidas), recuperar (restaurar e monitorar).
4. Post-Incident Activity	Lições aprendidas, revisão pós-incidente, melhorar playbooks e detecções.

Obs.: o ciclo é **circular** — as lições aprendidas alimentam de volta a preparação. E entre as fases 2 e 3 há idas e vindas (você descobre mais coisas enquanto contém). Em 2025 o NIST publicou a revisão 3 (800-61r3), alinhada ao CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover), mas o projeto usa a r2.

Mapeando o caso Cascadia

Momento	Evento	Fase	Lição
Dia 0, 19:42	3 tickets: drives inacessíveis	Detection	Os primeiros sinais muitas vezes chegam pelo help desk, não pelo SIEM.
Dia 0, 20:15	Analista confirma criptografia e liga para o IR lead	Analysis	Validar + **escalar**, não remediar sozinho.
Dia 0, 20:30	Plano ativado, bridge aberta, CISO notificado	Detection & Analysis (declaração / notificação)	Só funciona porque houve **Preparation** (plano existia).
Dia 0, 21:00	Isolar file servers; imagens médicas continuam online	Containment	Contenção **seletiva**: segurança vs. continuidade do cuidado ao paciente.
Dia 0, 22:00	Imagens forenses antes da remediação	Containment (preservação de evidências)	Evidência **antes** de mexer.
Dia 1, 03:00	Vetor: phishing → RDP com conta admin	Analysis (escopo / causa raiz)	Saber a entrada define o que erradicar.
Dia 1, 09:00	Contenção completa, contas desativadas	Containment / Eradication	Desativar contas comprometidas = remover o acesso do atacante.

Dia 2	Restore de backup limpo, monitoração ajustada	Recovery	Recuperar e **vigiar** para reinfecção.
Dia 3	Serviços restaurados; jurídico inicia avaliação HIPAA	Recovery + obrigação regulatória	Notificação legal é parte da resposta.
Dia 14	Revisão pós-incidente: 3 lacunas, 2 regras novas	Post-Incident Activity	Retroalimenta a Preparation.

> **Para o quiz, lembre:**
> - Ligar para o IR lead em vez de remediar sozinho = boa prática de **escalação** (Detection & Analysis).
> - Imagens forenses antes da remediação = **preservação de evidências**, parte de Containment.
> - Manter imagens médicas online = **trade-off** entre contenção e segurança do paciente.
> - Restaurar de backup + ajustar monitoramento = **Recovery**.
> - Novas regras de detecção / lacunas do playbook = **Post-Incident** (lessons learned).
> - HIPAA: a lei dá até **60 dias** após a descoberta para notificar os indivíduos; se >500 pessoas, notificar também o HHS e a mídia.

Resumo do que aprender

- As 4 fases do NIST e o que pertence a cada uma.
- Saber classificar ações típicas (isolar, imagem forense, restore, lições aprendidas).
- Entender que "Preparation" é exatamente o produto deste projeto.

Tarefa 1 — Matriz de Severidade (`severity_matrix.md`)

Objetivo: criar uma **linguagem comum** de gravidade. "SEV1" precisa significar a mesma coisa para o analista Tier 1, para a CISO e para a advogada.

> **Analogia:** é a triagem de Manchester do pronto-socorro. A enfermeira não decide "no feeling": olha critérios objetivos e atribui uma cor. Cada cor tem um tempo máximo de atendimento e um responsável.

Estrutura obrigatória

1. **Purpose** — máx. 2 frases.
2. **Severity Matrix** — tabela SEV1→SEV4 × 5 critérios.
3. **Level Definitions** — uma subseção por nível com 2–3 exemplos *específicos da MedDefense*.
4. **Escalation Rule** — como subir/descer a severidade durante o incidente.

Os 5 critérios (valores permitidos — use exatamente estes!)

Critério	Valores	O que mede
Patient Safety Impact	`none, low, moderate, high`	Risco à vida/saúde do paciente. **Exclusivo de hospital** — é o critério mais importante aqui.
Data Exposure	`none, suspected, confirmed_limited, confirmed_broad`	Confidencialidade de dados (PHI). Liga com HIPAA.
Service Availability	`none, degraded, partial_outage, full_outage`	Disponibilidade dos sistemas.
Max Response Time	em **minutos** (ex.: 15, 30, 60, 240)	Tempo máximo para começar a responder.
Decision Authority	**Cargo/papel**, nunca nome de pessoa	Quem tem a palavra final.

> **Por que papel e não pessoa?** Pessoas tiram férias, mudam de empresa, não atendem às 3h. Um papel ("IR Commander") sempre tem titular e backup. A tarefa corrige isso — "James Chen" na coluna = erro.

Como pensar os níveis

- **Escalonamento progressivo:** quanto mais grave, menor o tempo de resposta e mais alta a autoridade (SEV4 = SOC Analyst, 240 min → SEV1 = CISO, 15 min).
- **Regra "o pior critério manda":** se um único critério está em nível SEV1 (ex.: paciente em risco alto), o incidente é SEV1, mesmo que os outros sejam baixos. Vale escrever isso.
- **Exemplos concretos** e do contexto hospitalar: Epic, PACS/imagens, monitores de pacientes, 3 sites.

Ideias de exemplos para SEV3 e SEV4 (o enunciado deixa "..."):

- SEV3: phishing reportado com clique mas sem credencial digitada; malware bloqueado pelo EDR numa estação administrativa; lentidão em sistema não clínico com suspeita de atividade anômala.
- SEV4: varredura de portas externa bloqueada no firewall; e-mail de phishing reportado e não aberto; falha de login isolada sem padrão.

Escalation Rule

Severidade é **dinâmica**: revista a cada atualização de status. Sobe quando surge evidência nova (mais dados, mais sistemas, impacto no paciente). Desce **somente** após contenção confirmada e aprovação de quem tem autoridade. Subir é fácil; descer exige prova.

Resumo do que aprender

- Classificação de severidade baseada em critérios objetivos, não em intuição.
- Em saúde, impacto no paciente pesa tanto quanto (ou mais que) dados.
- Vincular cada nível a tempo de resposta e autoridade de decisão.
- Respeitar exatamente os valores permitidos (a correção é automática!).

Tarefa 2 — Estrutura do time e escalação (`ir_team_structure.yaml`)

Objetivo: ninguém deve perguntar "quem decide isso?" durante o incidente. A resposta está no papel.

Os 6 papéis

Papel	Função	Sugestão MedDefense	Teto sugerido
IR_Commander	"Dono" do incidente: coordena, conduz a bridge, autoriza contenção.	James Chen (backup Robert Kim)	SEV2
Technical_Lead	Comanda a investigação e as ações técnicas (forense, isolamento, reset).	Robert Kim (backup Mike Torres)	SEV3
Communications_Lead	Mensagens internas/externas: staff, imprensa, pacientes.	Marcus Webb	SEV3 (comunica, não decide contenção)
Legal_Liaison	Avaliação HIPAA, notificações, privilégio jurídico, preservação legal.	Helena Reyes	SEV2
Executive_Sponsor	Decisões de negócio: desligar sistemas clínicos, pagar recursos externos, falar com o board.	Dr. Patricia Morales (backup Sarah Park)	SEV1
Scribe	Registra a timeline, decisões e quem as tomou (essencial para auditoria).	Um analista do SOC	SEV4

Os nomes acima são sugestões; confira o arquivo `meddefense_profile.md` do projeto, que pode listar mais funcionários (ex.: analistas, líder clínico).

Campos de cada papel

- `primary` e `backup`: "Nome, Cargo" (aqui sim usa nome de pessoa).
- `responsibilities`: **no máximo 3** itens.
- `authority_ceiling`: a severidade mais alta que o papel pode conduzir sozinho. Acima disso, escala.

Bloco `escalation` (para SEV1, SEV2, SEV3, SEV4)

Campo	Quando
on_detection	Quando o incidente é declarado.
on_confirmation	Quando o comprometimento é confirmado.
on_scope_expansion	Quando o escopo cresce além do inicial.
time_threshold_minutes_to_escalate	Quanto tempo sem progresso antes de subir um nível.

Lógica: SEV1 notifica quase todos já na detecção (incluindo Executive_Sponsor, Legal, Comms) e tem threshold curto (ex.: 30). SEV4 notifica só o IR_Commander/Technical_Lead e tem threshold longo (ex.: 480). Note que Legal entra **na confirmação** porque comprometimento confirmado pode virar obrigação HIPAA. O Scribe deve entrar cedo nos SEV1/SEV2 — a timeline começa no primeiro minuto.

Coerência: o teto do IR_Commander (SEV2) deve bater com a "Decision Authority" de SEV2 na matriz (IR Commander). O de SEV1 (CISO) bate com o Executive_Sponsor. Cuidado com indentação YAML (2 espaços, sem tabs).

Resumo do que aprender

- Papéis de um CSIRT e a separação comando × técnico × comunicação × jurídico.
- Conceito de **teto de autoridade** e de escalação por gatilho e por tempo.
- Sempre ter backup (ninguém é ponto único de falha).
- Escrever YAML válido.

Tarefa 3 — Template de playbook (`playbook_template.yaml`)

Objetivo: "Padronize antes de escalar". Todo playbook responde às mesmas perguntas na mesma ordem. O analista cansado sabe onde olhar.

> **Analogia:** é a checklist do piloto de avião. Todas têm o mesmo formato, então em emergência ninguém procura informação — só segue.

Seções e o que cada uma responde

Seção	Pergunta que responde
playbook_id, title, owner_role	Que playbook é, e qual **papel** o executa?
applies_to (triggers, indicators)	Quando uso este playbook? Que alertas/IOCs o disparam?
severity_mapping (initial, escalate_if)	Começo em qual SEV? O que faz subir?
immediate_actions	O que faço nos **primeiros 15 minutos**? (step, owner, timebox)
evidence_preservation	O que capturar **antes** de conter? (artifact, method, before_step)
containment_actions	Como paro o ataque? Cada ação tem **trade_off** e possível decision_point.
eradication_actions	Como removo o atacante/persistência?
recovery_validation	Como provo que voltou ao normal? (check + critério de aprovação)
communication_plan	Quem informo, quando, com qual template?
escalation_triggers	O que me obriga a escalar?
post_incident_tasks	O que vai para a revisão pós-incidente?

O template **não é preenchido**: usa placeholders `<...>`. Siga a estrutura do "Expected output" à risca (nomes de chaves exatos: `before_step`, `trade_off`, `timebox_minutes`...).

Os três conceitos mais importantes

- **Evidence before containment** (`before_step`): resetar uma senha ou reiniciar um servidor apaga evidência (sessões, memória RAM, logs voláteis). Ordem de volatilidade (RFC 3227): memória → conexões de rede → processos → disco → logs/backups.
- **Trade-off explícito:** toda contenção custa algo — visibilidade do atacante, disponibilidade de serviço, produtividade. Escrever isso força a decisão consciente.
- **Owner + timebox:** cada passo tem dono (um papel) e prazo. Sem dono, ninguém faz.

Resumo do que aprender

- A anatomia de um playbook operacional.
- Por que padronizar facilita execução sob pressão.
- Ordem lógica: detectar → classificar → agir rápido → preservar → conter → erradicar → validar → comunicar → aprender.

Tarefa 4 — Playbook: Exposição de credenciais

Cenário: usuário digita a senha numa página falsa da Microsoft (phishing). Em menos de 1h, o atacante faz login de um IP estrangeiro.

Regra: preencher **todas** as seções do template, **sem criar seções novas**. Outro analista deve executar sem perguntar nada.

Entendendo o ataque

- **Credential phishing**: página falsa coleta usuário e senha.
- Variante moderna: **AiTM (Adversary-in-the-Middle)**, com kits como Evilginx — o proxy falso repassa o login real e rouba o **cookie/token de sessão**. Por isso o atacante "passa" pelo MFA.
- Consequência: **só trocar a senha não basta** — o token de sessão continua válido. Precisa revogar sessões.

Ordem correta (o coração da tarefa)

1) Evidência ANTES de qualquer reset:

- Logs de autenticação (AD / Domain Controllers: eventos 4624, 4625, 4768, 4769).
- Export do **Azure AD (Entra ID) sign-in log** (IP, país, user-agent, app, resultado MFA).
- Export da **mailbox** afetada (regras de encaminhamento criadas pelo atacante, e-mails enviados — phishing interno).
- Export da **auditoria de acesso a dados recentes** (Epic access log, SharePoint/OneDrive, drive clínico).

2) Contenção concreta (as 5 exigidas):

Ação	Por quê	Trade-off
Reset de senha no Active Directory	Invalida a credencial roubada.	Usuário fica sem acesso até receber nova senha; perde-se visibilidade.
Revogação de sessões no Azure AD (Revoke-MgUserSignInSession / "Revoke sessions")	Mata os tokens de refresh já roubados.	Desconecta o usuário legítimo de todos os apps.
Reset do dispositivo MFA	Atacante pode ter registrado o próprio celular como MFA.	Usuário precisa re-registrar MFA (apoio do help desk).
Revogação de token VPN	Impede acesso à rede interna.	Trabalho remoto do usuário interrompido.
Terminar sessão no Epic	Corta acesso direto a prontuários (ePHI).	Se for clínico em plantão, pode afetar o atendimento — coordenar.

Gatilho HIPAA

Pergunta-chave: **havia ePHI acessível pela conta durante a janela de exposição** (do momento do phishing até a contenção)? Se sim → Legal_Liaison inicia a avaliação de breach.

Pela HIPAA, um acesso não autorizado a PHI é **presumido breach**, a não ser que uma avaliação de risco mostre baixa probabilidade de comprometimento, considerando 4 fatores:

1. Natureza e extensão da PHI (tipos de dados, identificadores).
2. Quem acessou sem autorização.
3. Se a PHI foi de fato adquirida ou visualizada.
4. Em que medida o risco foi mitigado.

Ponto de decisão obrigatório

Opção A: resetar imediatamente	Opção B: monitorar brevemente
+ Corta o atacante já, limita dano e exposição de ePHI. − Perde visibilidade: não vê o que ele queria, outras contas, persistência.	+ Aprende TTPs, descobre escopo real. − Risco de exfiltração, movimento lateral, mais pacientes afetados.

Em hospital com acesso a ePHI, o padrão defensável é **conter imediatamente**; monitorar só com timebox curto, aprovação do IR_Commander e se a conta não tiver acesso a dados sensíveis. Documente **quem decide** e **o critério**.

Erradicação e recuperação

- Remover regras de inbox maliciosas, apps OAuth consentidos, dispositivos MFA estranhos.
- Bloquear IP/domínio do phishing; purgar o e-mail das outras caixas.
- Validar: nenhum login do IP estrangeiro após reset, sessões antigas inválidas, MFA re-registrado pelo usuário verdadeiro.

Resumo do que aprender

- Phishing de credenciais, AiTM e por que MFA não é garantia absoluta.
- Diferença senha × sessão/token; ambiente híbrido AD + Azure AD.
- Preservar evidência antes de conter.
- Avaliação de breach HIPAA e o papel do jurídico.
- Formalizar uma decisão difícil com seus trade-offs.

Tarefa 5 — Playbook: Degradação de serviço clínico

Cenário: o servidor de imagens de radiologia (tipicamente **PACS**) está lento; enfermeiras não conseguem ver raios-X de pacientes no pronto-socorro. Pode ser desempenho, pode ser ataque. **Você não pode simplesmente desligar.**

> **Analogia:** um paciente com febre durante uma cirurgia. Você não para a cirurgia para investigar — investiga com cuidado enquanto mantém o paciente vivo. Segurança da informação aqui serve à segurança do paciente.

1) Triagem: incidente ou desempenho?

Indicadores de problema de desempenho	Indicadores de incidente
• Correlação com pico de uso, backup agendado ou update recente • Disco cheio, falha de hardware, alertas de storage • Processos conhecidos consumindo CPU/RAM • Sem tráfego para destinos desconhecidos • Mudança registrada no change management	• Processos desconhecidos / alerta de EDR • Arquivos renomeados ou extensões estranhas (ransomware) • Tráfego de saída anômalo (exfiltração, C2) • Logins fora do padrão, contas de serviço usadas interativamente • Alto I/O de disco com criptografia, consultas DICOM em massa • Mudanças sem change ticket

2) Contenção parcial (sem derrubar o serviço)

- **Segmentação de rede:** restringir o servidor para falar só com estações clínicas/modalidades necessárias; bloquear saída para internet (Mike Torres).
- **Restrição de contas:** desativar contas suspeitas, limitar admin, só contas clínicas essenciais.
- **Throttling de serviço:** limitar conexões/consultas, pausar jobs não críticos (sincronização, backups pesados).

Cada uma com `trade_off`: ex. segmentar pode cortar acesso a um site remoto que precisa das imagens.

3) Coordenação de segurança do paciente

Antes de **qualquer isolamento**, contatar um **papel clínico** (ex.: Clinical Lead de plantão / Chief Medical Officer / Nurse Manager do ER / Radiology Director). Só a área clínica sabe se há pacientes críticos dependendo do sistema naquele momento.

4) Fallback clínico: downtime procedures

Defina o **momento exato** em que o líder clínico de plantão ativa os procedimentos de contingência — ex.: "antes de qualquer ação que interrompa o acesso" ou "se a latência passar de X minutos por imagem". Exemplos: laudos por telefone, imagens vistas direto na modalidade, desvio de ambulâncias para outro site em caso extremo.

5) Ponto de decisão

Investigar em downtime	Manter serviço com monitoramento reforçado e acesso restrito
+ Melhor contenção e forense. − Atendimento depende de processos manuais; risco clínico.	+ Cuidado ao paciente continua. − Atacante (se houver) pode continuar agindo; evidência pode ser alterada.

Critério típico: indicadores fortes de incidente (ransomware, exfiltração) → downtime; indicadores fracos/ambíguos → serviço contínuo com monitoramento. Quem decide: IR_Commander junto com o papel clínico; se impacto alto no paciente → SEV1, Executive_Sponsor.

Resumo do que aprender

- Em saúde, disponibilidade = segurança do paciente.
- Distinguir incidente de problema operacional com indicadores concretos.
- Contenção gradual (parcial) em vez de "tudo ou nada".
- Integrar a área clínica nas decisões de IR.

Tarefa 6 — Validar o plano contra um alerta real

Tipo: quiz. Você deve responder usando **só os seus artefatos**. Se não conseguir, os artefatos precisam de outra revisão.

O alerta (03:14, terça-feira)

- **Impossible travel** na conta `rchen` (enfermeira, Site A): login em Moscou 03:08 UTC; login anterior em Seattle às 18:22 UTC do dia anterior.
- Acesso a **Epic**, drive clínico compartilhado e **console de auditoria do EHR**.
- Autenticação bem-sucedida, **MFA concluído**.
- Nenhuma sessão encerrada; 15 min até o primeiro status para a CISO.

Como analisar

1. **Qual playbook?** Exposição de credenciais (Tarefa 4).
2. **MFA concluído não prova legitimidade:** pode ser roubo de token (AiTM), MFA fatigue (usuário aprovou push sem querer), ou dispositivo MFA do atacante. ~9h entre Seattle e Moscou = viagem fisicamente impossível. Descartar só se houver explicação (VPN corporativa, viagem registrada) — e confirmar com o usuário/gerente por canal separado.
3. **Severidade:** pela sua matriz, "comprometimento confirmado de conta com acesso clínico" = **SEV2** (resposta ≤30 min, IR Commander). Sobe para **SEV1** se houver exfiltração ampla de prontuários ou impacto no paciente.
4. **Risco especial — console de auditoria do EHR:** o atacante poderia **apagar ou alterar rastros** de acesso a prontuários. Por isso, exportar os logs de auditoria é prioridade máxima, antes de tudo.
5. **Sequência:** declarar o incidente e acionar o IR_Commander → preservar evidência (sign-in logs Azure AD, auditoria Epic/EHR, mailbox, acessos ao drive) → conter (revogar sessões Azure AD, reset de senha, reset MFA, VPN, encerrar sessão Epic) → Legal_Liaison avalia HIPAA (havia ePHI acessível? sim → avaliação de breach) → status para a CISO no prazo.
6. **Atenção clínica:** rchen é profissional de saúde — se estiver de plantão, coordene para não interromper atendimento (mas a conta está sendo usada de Moscou: conter vence).

> **O que esse teste ensina:** "valide um design executando-o, não revisando-o". Se seu playbook não diz o que fazer quando MFA foi concluído, ou não menciona o console de auditoria, você descobriu uma lacuna — exatamente como o Dia 14 do caso Cascadia.

Síntese final

Os 3 objetivos transversais

- **Escrever para operadores, não leitores:** frases curtas, verbos de ação, dono e prazo em cada passo. Nada de teoria.
- **Padronizar antes de escalar:** template primeiro, playbooks depois.
- **Validar executando:** tabletop exercises, simulados, alertas de teste.

Os 3 objetivos conceituais

- **Alinhar IR à regulação de saúde:** HIPAA (avaliação de breach, prazo de 60 dias, notificação HHS/mídia se >500). No contexto europeu (Luxemburgo), o equivalente seria o **GDPR** (notificação à autoridade em 72h) e a diretiva **NIS2** (alerta inicial em 24h) — bom para entrevistas!
- **Autoridade de decisão por severidade:** quanto mais grave, mais alto quem decide.
- **Evidência × continuidade:** o trade-off central. Preservar evidência atrasa a contenção; conter rápido destrói evidência; em hospital, ainda há a vida do paciente.

Checklist antes de entregar

- ☐ Arquivos no repositório `dlh-cyber_security`, pasta `ir_dfir_playbook/5x00_incident_response`.
- ☐ Nomes exatos: `severity_matrix.md`, `ir_team_structure.yaml`, `playbook_template.yaml`, `playbook_credential_exposure.yaml`, `playbook_clinical_degradation.yaml`.
- ☐ Valores permitidos da matriz usados exatamente (`confirmed_limited`, `partial_outage`...).
- ☐ Decision Authority = papel, não pessoa.
- ☐ YAML válido (teste com `python3 -c "import yaml; yaml.safe_load(open('arquivo.yaml'))"` ou `yamllint`).
- ☐ Nomes de papéis iguais em todos os arquivos.
- ☐ Playbooks não adicionam seções novas ao template.
- ☐ Evidência listada antes da contenção; cada contenção com `trade_off`.
- ☐ Ler o `meddefense_profile.md` (lab materials) para nomes e sistemas reais da empresa.

Recursos para estudar

- NIST SP 800-61r2 — seção 3 (ciclo de vida) e seção 2 (estrutura do time).
- HHS — HIPAA Breach Notification Rule (45 CFR 164.400–414).
- CISA Federal Incident Response Playbooks — ótimo exemplo de formato de playbook.
- FIRST CSIRT Services Framework — papéis e serviços de um CSIRT.
- NIST SP 800-184 — recuperação; ISO/IEC 27035-1 — gestão de incidentes.